

AHS Vault — UK Enterprise-Ready

Remaining Docs: Why You Need Each + How to Get It

B2B SaaS | You-host relay + BYO Drive | Finance + NHS + Gov | UK Ltd exists | Date: 2026-09-11

Companion to **INSTANT_DOCS_GUIDE.pdf** (what you can draft from code today) and **ENTERPRISE_DOCS_CHECKLIST.txt** (all 71). This file covers the **other docs** — everything that needs an external body, auditor, payment, waiting time, or code fixes first. For each: **why it blocks a UK sale, who asks for it, prerequisites in your repo, exact how-to-get steps, lead time / validity**.

Your repo reality (from code read): relay is plaintext :8080 (main.go), CORS * (router.go), unauth endpoints trusting ?public_key= (handlers.go), hardcoded Google OAuth secret (oauth.rs), leaked Tauri signing key (PRODUCTION_SETUP_GUIDE_V2.md), plaintext **onboarding.json** mnemonic, full-mail IMAP fetch (shield.rs), Google Fonts fetch (index.css), host **ahs.mayfairmarketing.online**. Fix these BEFORE booking paid audits or you will fail and pay twice.

#1-2	Companies House pack (Incorp. Cert + Confirmation + PSC)	COMPANY — download now
WHY NEEDED: WHY: every UK enterprise/NHS/gov onboarding asks for company number, registered office, directors/PSC. No pack = no vendor setup, no MSA signature.		
WHO ASKS: procurement, finance, G-Cloud, banks (KYC).		
HOW TO GET: HOW: 1) Find company number at find-and-update.company-information.service.gov.uk. 2) Download Incorporation Certificate + latest Confirmation Statement + PSC from filing history (free). 3) File anything overdue + board minute authorising AHS Vault product and data processing. Save in legal/COMPANY/.		
TIME: same day if filings up to date. VALID: keep confirmation statement yearly.		

#3	IP Assignment Agreements (all contributors to Ltd)	COMPANY — solicitor template
WHY NEEDED: WHY: buyers + investors check you own the code (Rust/Go/React/Kotlin). Without assignment, a contributor can claim the crypto/vault code.		
WHO ASKS: legal, investors, acquirers, ISO A.5 / SOC CC.		
HOW TO GET: HOW: 1) List every committer (git log). 2) Each signs IP assignment to your Ltd (past + future work, moral rights waiver). 3) Store signed PDFs in legal/IP/. Also fix Cargo.toml/package.json/go.mod license+repository fields to match your LICENSE choice.		
TIME: 1-2 weeks chasing signatures.		

#4	UKIPO Trademark (AHS Vault / BritSync)	IP — UKIPO
WHY NEEDED: WHY: stops copycats, needed for app stores + enterprise brand trust. NHS/gov check brand ownership.		
WHO ASKS: app stores (disputes), legal, partners.		
HOW TO GET: HOW: 1) Search trademarks.service.gov.uk (classes 9 software, 38 comms, 42 SaaS). 2) Apply online (one mark, fee per class). 3) Respond to examiner, await opposition (2 months) then registration. Use TM solicitor if contested.		
TIME: 3-4 months if clean. VALID: 10 years renewable.		

#5	HMRC VAT + Corporation Tax refs	COMPANY — HMRC
WHY NEEDED: WHY: B2B invoices need VAT number; enterprise AP blocks payment without it.		
WHO ASKS: customer finance/AP.		
HOW TO GET: HOW: 1) Government Gateway -> HMRC -> VAT registration (threshold £90k, or voluntary). 2) Note Corporation Tax UTR from HMRC letter. 3) Put VAT no. on Order Form/invoices. Save in finance/.		
TIME: VAT 1-4 weeks.		

#6-7	PI Insurance (£2-5M) + Cyber Insurance certs	COMPANY — broker
------	--	------------------

WHY NEED: WHY: finance/NHS/gov RFPs mandate minimum cover. No cert = auto-fail. Covers breach/negligence claims.

WHO ASKS: procurement, RFP mandatory pass/fail.

HOW TO GET: HOW: 1) Broker (tech/PI + cyber). Disclose: SaaS vault, crypto, biometrics, BYO Drive, IMAP shield, UK hosting plan. 2) Align wording with MSA liability cap + SLA. 3) Get certificates naming your Ltd, save in legal/INSURANCE/ + attach to CISO pack.

TIME: 1-3 weeks. **VALID:** yearly renewal.

#9-12	EULA + MSA/Order + SLA + Acceptable Use (FINAL signed)	LICENCE — solicitor final
-------	--	---------------------------

WHY NEED: WHY: draft exists from instant guide, but B2B sale is void without signed governing law (England & Wales), licence scope (per-seat, non-transferable), fees/renewal/termination, 99.9% SLA + credits, customer duties (protect 24-word mnemonic, manage Drive), liability cap, right-to-audit, exit/return-delete.

WHO ASKS: legal, procurement, banks (resilience + audit rights).

HOW TO GET: HOW: 1) Solicitor reviews PART-B drafts against your hosting model (you-host relay + BYO Drive — customer owns Drive data). 2) Sign MSA per customer + Order Form per deployment. 3) Publish EULA in installers/stores + Acceptable Use on website. Store executed copies.

TIME: 2-4 weeks legal review.

#14-15	Code-signing + Store trust + public TLS	LICENCE/TRUST — CA/Apple/Google
--------	---	---------------------------------

WHY NEED: WHY: Windows SmartScreen blocks unsigned .exe/.msi; Apple notarization required; Play requires signing + Data Safety; browsers flag http :8080. Your updater key leaked — must rotate before any release.

WHO ASKS: end-user devices, IT admins, MDM.

HOW TO GET: HOW: 1) Buy EV Code Signing cert (CA verifies Ltd identity, USB token/HSM) -> sign Tauri nsis/msi in build-windows.yml (replace leaked TAURI_SIGNING_PRIVATE_KEY via GitHub Secrets, new pubkey in tauri.conf.json). 2) Apple Developer ID + notarize. 3) Play App Signing + complete Data Safety form + Play DPA. 4) Public TLS (DigiCert/LE) for relay, force https + HSTS, sslmode=require, move off mayfairmarketing.online to owned domain with SPF/DKIM/DMARC.

TIME: EV 1-3 weeks (vetting). TLS same day. Stores days.

#16	ICO Controller Registration (number)	GOV PERMISSION — ICO
-----	--------------------------------------	----------------------

WHY NEED: WHY: UK GDPR Art. requirement for controllers. Buyers check the public ICO register + ask for number in Privacy Notice/DPA.

WHO ASKS: every B2B DPA, NHS IG, RFP.

HOW TO GET: HOW: 1) ico.org.uk -> Register (tier by staff/turnover, direct-debit fee). 2) Publish number in Privacy Notice + DPA + website footer. 3) Renew yearly.

TIME: 1-7 days. **VALID:** yearly.

#17-23	Privacy finals: Notice + DPA signed + ROPA + DPIA + LIA + TRA/IDTA	PRIVACY — DPO + solicitor + ICO templates
--------	--	---

WHY NEED: WHY: DPIA is MANDATORY for biometrics + large-scale vault + mail scanning (Art.35). No signed DPA/IDTA = no lawful US transfer to Google/GitHub/Fonts. NHS IG rejects without DPIA+ROPA.

WHO ASKS: DPO, customer IG, NHS, banks.

HOW TO GET: HOW: 1) DPO signs ROPA/DPIA/LIA drafts (instant guide) after you fix: IMAP behind opt-in + minimisation + redaction, stop logging PK/nonce/tokens, encrypt onboarding.json/IndexDB, unify PIN KDF, self-host fonts or list with TRA. 2) Sign customer DPA per deal + sub-DPAs (Google, host). 3) Complete TRA + UK IDTA per US sub-processor (ICO template). 4) Move relay+Postgres to eu-west-2 London for regulated pilots. File in legal/PRIVACY/ + evidence for DSPT/DTAC.

TIME: 2-6 weeks after code fixes. Review yearly / on change.

#24-27	Retention/Deletion + DSAR + Breach + DPO (operational)	PRIVACY OPS — DPO
--------	--	-------------------

WHY NEED: WHY: buyers test deletion (DB + Drive purge proof) and DSAR 1-month SLA; breach 72h ICO clock is law.

WHO ASKS: IG, support, auditors.

HOW TO GET: HOW: 1) Implement retention (e.g. activity_logs 12 mo, devices/blobs per contract) + delete endpoints verified via Get/Delete + Drive purge (gdrive.go). 2) DSAR intake/ID-verify/search-by-public_key/redact/respond/log + drill. 3) Breach playbook: detect-contain-assess-notify controller-ICO 72h-subjects if high risk. 4) Formal DPO appointment letter (internal or DPO-as-a-service, mandatory at health scale). Log drills.

TIME: 2-4 weeks to operationalise.

#28	Cyber Essentials (basic)	SECURITY CERT — IASME
-----	--------------------------	-----------------------

WHY NEED: WHY: minimum for any UK gov contract; baseline for all enterprise. Required before CE+.

WHO ASKS: gov procurement (mandatory), all RFPs.

HOW TO GET: HOW: 1) IASME portal self-assessment: firewalls, config, patching, accounts, malware (cover relay, Postgres, CI runners, dev laptops). 2) Fix: HTTPS/HSTS, patch cadence (Dependabot), remove hardcoded secrets, MDM/AV evidence. 3) Submit + assessor review.

TIME: 1-4 weeks. VALID: 12 months.

#29	Cyber Essentials Plus (audited)	SECURITY CERT — IASME Plus auditor
-----	---------------------------------	------------------------------------

WHY NEED: WHY: audited proof; required for NHS/gov sensitive + de-facto for finance. CE self-claim is not enough.

WHO ASKS: NHS, gov, banks.

HOW TO GET: HOW: 1) Pass CE first. 2) Book licensed Plus auditor (on-site/remote build + malware + network tests on desktop/backend/mobile samples). 3) Remediate fails (expect: plaintext transport, CORS *, missing MDM, unsigned builds) + retest. Save cert in CISO pack.

TIME: 1-3 months incl. remediation. VALID: 12 months.

#30-31	ISO 27001:2022 (+ SoA) + 27701 privacy	SECURITY CERT — UKAS auditor
--------	--	------------------------------

WHY NEED: WHY: must-have for finance/gov RFPs. Proves ISMS, not just point controls.

WHO ASKS: CISO, procurement (often scored).

HOW TO GET: HOW: 1) Scope ISMS (relay + dev + support). 2) SoA + risk treatment + policy suite (item 53) + evidence (PART-A docs, scans, access logs, supplier reviews). 3) Stage 1 (docs) then Stage 2 (practice) with UKAS auditor. 4) 27701 extension adds privacy controls (maps to ROPA/DPIA).

TIME: 3-9 months. VALID: 3-yr cycle + yearly surveillance.

#32	SOC 2 Type II	SECURITY CERT — CPA auditor (US-accepted)
-----	---------------	---

WHY NEED: WHY: banks/US buyers expect it alongside ISO. Type II observes controls over 3-12 months.

WHO ASKS: banks, US enterprise.

HOW TO GET: HOW: 1) Define Trust Criteria (Security + Availability + Confidentiality). 2) Type I (design) then Type II observation window with evidence (change logs, access reviews, backup tests, IR drills). 3) Report shared UNDER NDA only.

TIME: Type I 2-3 mo, Type II 3-12 mo observation. VALID: 12 mo.

#33	PSTI Act 2024 Statement of Compliance	PRODUCT LAW — Trading Standards
-----	---------------------------------------	---------------------------------

WHY NEED: WHY: you ship consumer-connectable apps (mobile/desktop). Sale without SoC + CVD contact + support period is an offence.

WHO ASKS: retailers, Trading Standards, enterprise (supply-chain duty).

HOW TO GET: HOW: 1) Fix: no default passwords, CVD contact in SECURITY.md, defined support/update window. 2) Publish signed SoC (manufacturer, product, support end date) with product + website. 3) Keep update chain signed post-rotation.

TIME: days after fixes. Keep per release.

#34	NHS DSPT (Data Security Protection Toolkit)	GOV/NHS — NHS England portal
-----	---	------------------------------

WHY NEED: WHY: mandatory to hold/process NHS data. No assessed DSPT = no NHS pilot.

WHO ASKS: NHS IG, ICB/Trust.

HOW TO GET: HOW: 1) Register org on DSPT portal. 2) Evidence: CE+, ISO/SoA, DPIA/ROPA/DPA, training, backup/IR tests, access control (map to items 40-53). 3) Publish assessed status, renew yearly.

TIME: 1-3 months after CE+/ISO base.

#35	NHS DTAC (Digital Technology Assessment Criteria)	GOV/NHS — Trust assessors
-----	---	---------------------------

WHY NEED: WHY: mandatory for NHS tech: clinical safety, technical, interoperability, usability, accessibility.

WHO ASKS: NHS clinical + IT + procurement.

HOW TO GET: HOW: 1) Complete DTAC workbook with evidence: arch/DFDs, pen test, WCAG audit, usability/UAT, BCP/DR, hosting (UK), exit plan. 2) Trust review + sign-off per deployment.

TIME: 1-2 months after evidence ready.

#36	DCB0120/0160 + CSO + Hazard Log + Safety Case	NHS CLINICAL — CSO
-----	---	--------------------

WHY NEED: WHY: required if vault touches care pathways (stores/shares health info). Unassessed clinical risk blocks go-live.

WHO ASKS: NHS clinical safety.

HOW TO GET: HOW: 1) Appoint Clinical Safety Officer. 2) Hazard log + mitigations + Safety Case (manufacturer DCB0120, deployer DCB0160 jointly). 3) Sign-off per release.

TIME: 1-3 months. Maintain per release.

#37	G-Cloud / Digital Marketplace listing	GOV SALES — Crown Commercial Service
-----	---------------------------------------	--------------------------------------

WHY NEED: WHY: how gov/NHS buy SaaS compliantly without full tender.

WHO ASKS: gov buyers.

HOW TO GET: HOW: 1) Await G-Cloud round (periodic). 2) Submit service + pricing + terms + security answers (reuse CAIQ/CE+/ISO/DSPT). 3) Maintain listing + respond to call-offs.

TIME: per CCS timetable (weeks).

#38	UK Export Control crypto record (ECJU 5A002/5D002)	GOV PERMISSION — ECJU
-----	--	-----------------------

WHY NEED: WHY: AES-256 distribution outside UK may need licence/exemption record. Auditors ask.

WHO ASKS: legal, export compliance, acquirers.

HOW TO GET: HOW: 1) Classify (mass-market crypto usually exempt — record rationale). 2) If controlled, apply for OGEL/licence on SPIRE. 3) File record + screen customers/territories.

TIME: assessment days; licence weeks if needed.

#39	WCAG 2.2 AA audit + Accessibility Statement	EQUALITY LAW — external DAC-style auditor
-----	---	---

WHY NEED: WHY: Equality Act 2010 + Public Sector Bodies Regs block gov/NHS sale without AA + statement.

WHO ASKS: gov/NHS procurement (mandatory), all enterprise.

HOW TO GET: HOW: 1) Auditor tests desktop/web/mobile (keyboard, SR JAWS/NVDA/VoiceOver, contrast, focus). 2) Fix + retest. 3) Publish statement (scope, conformance, contacts, review date).

TIME: 2-6 weeks.

#57-61	Signed commercial pack (DPA pack + pen-test summary + certs + BCP + pilot SOW)	SALES — per-deal
--------	--	------------------

WHY NEED: WHY: this is what you actually email a CISO under NDA to win a pilot.

WHO ASKS: CISO, IG, procurement.

HOW TO GET: HOW: 1) Zip: certs (CE+/ISO/SOC), pen-test exec summary <12 mo + retest letter (NOT full exploit), DPIA summary, signed DPA + subprocessors + IDTA, SBOM summary, arch/DFD, BCP/DR+RPO/RTO, IR contacts+SLA, insurance+ICO+PSTI+accessibility, roadmap/support. 2) Mutual NDA first for SOC2/full pen test. 3) Pilot SOW with success criteria + exit/return-delete + UTR.

TIME: assemble in days once certs exist.

#62-63	Functional + CREST/CHECK Pen Test (final reports)	TEST — CREST/CHECK/TIGER provider
--------	---	-----------------------------------

WHY NEED: WHY: only independent test buyers trust. Internal agent audits do not count.

WHO ASKS: every regulated buyer (<12 mo, retest required).

HOW TO GET: HOW: 1) Raise coverage (Go/Rust/TS/Kotlin) + E2E (Playwright/Tauri/Android Biometric emulator). 2) Scope pen test: external relay, API (ASVS L2), desktop (binary, updater, FUSE/WebDAV), mobile (MASVS: Keystore, Tink, pinning, backup=false verify), WS abuse, rate-limit/DoS. 3) Fix criticals + paid retest. Share exec summary; full report under NDA.

TIME: testing 2-4 wks + remediation + retest. Repeat yearly.

#64	Independent Cryptography Audit	TEST — NCC/Cure53-style firm
-----	--------------------------------	------------------------------

WHY NEED: WHY: zero-knowledge is your core claim — buyers want a cryptographer to bless KDF/nonces/wire format, not just your README.

WHO ASKS: banks, high-assurance gov.

HOW TO GET: HOW: 1) Provide crypto spec (item 40) + code (crypto.rs/crypto.ts/CryptoManager/webauthn.go) + test vectors. 2) Fix: unify PIN KDF (Argon2id/PBKDF2), verify X25519+AES-GCM nonce uniqueness, P-256/WebAuthn checks, BIP-39 handling. 3) Publish letter/findings + fixes.

TIME: 3-6 weeks + fixes.

#65-66	CI scans (committed) + Load/Soak + TLS scans	TEST — run + commit
--------	--	---------------------

WHY NEED: WHY: proves secure SDLC + resilience. Cheap, do before paid audits.

WHO ASKS: auditors, CISO (CI evidence).

HOW TO GET: HOW: 1) Commit docs/scans/ (npm/cargo/govulncheck/gitleaks) + Dependabot + SAST/DAST in .github/workflows (gate merges). 2) k6 load/soak on relay (auth, upload/download/index, WS fan-out) + record p95/RPS/errors + fix unbounded temp upload + 1h timeouts. 3) SSL Labs + securityheaders scan after TLS/HSTS, save reports.

TIME: days-weeks.

#67	Backup Restore + DR Failover evidence	TEST — ops drill
-----	---------------------------------------	------------------

WHY NEED: WHY: RPO/RTO in SLA is fiction without a logged restore.

WHO ASKS: banks, NHS, auditors.

HOW TO GET: HOW: 1) pg_dump/PITR + encrypted off-site (not just postgres_data volume). 2) Quarterly restore to clean env + time it + verify blobs/index/ownership. 3) Failover drill (eu-west-2) + log. Attach logs to BCP.

TIME: 1-2 days per drill, quarterly.

#68-71	Accessibility + UAT + Clinical + DSAR/Deletion logs	TEST — auditor/users/DPO
--------	---	--------------------------

WHY NEED: WHY: each unblocks a specific buyer: AA for gov/NHS, UAT for users, Safety Case for care use, DSAR/deletion for IG.

WHO ASKS: procurement / clinicians / IG.

HOW TO GET: HOW: 1) DAC-style AA audit + fixes + statement. 2) UAT scripts with finance + NHS users + sign-off. 3) CSO Safety Case sign per release (if health). 4) DSAR drill + deletion verification (DB row + Drive blob purge via API, screenshot/log). File all in evidence/.

TIME: 2-6 weeks total; repeat per major release.

Suggested order (cheapest unblock first)

- 1. Company + HMRC + ICO (1-2,5,16) — days, unlocks vendor setup + DPA signing.
- 2. IP + TLS + signing rotation (3,14-15) — weeks, unblocks releases + trust.

- **3. Privacy finals with DPO (17-27) + UK hosting (eu-west-2)** — needs code fixes (IMAP opt-in, encrypted storage, redacted logs, self-host fonts).
- **4. Insurances + commercial finals (6-7,9-12,57-61)** — parallel with legal.
- **5. CE then CE+ (28-29)** — only after transport/auth/secrets fixed.
- **6. Pen test + crypto audit + scans/load (62-66)** — after fixes, share exec summary.
- **7. ISO 27001 + SOC 2 (30-32) + PSTI SoC (33) + AA (39) + Export record (38)** — start ISMS early, cert takes months.
- **8. NHS/Gov route (34-37 + 36 if clinical)** — needs CE+, DPIA, pen test, AA in hand.
- **9. Evidence upkeep (67-71)** — quarterly drills + per-release sign-offs.

Companion files: ENTERPRISE_DOCS_CHECKLIST.txt (71) + INSTANT_DOCS_GUIDE.pdf (draft-now). This guide = the rest. Re-check after each code fix; do not book paid audits until plaintext transport, CORS *, auth gaps, leaked keys, and IMAP over-collection are fixed.